

3



Módulo 03

Técnicas Utilizadas na Identificação de Ameaças

Aula 01

Gerenciamento de Vulnerabilidades

Introdução —

Nesta aula, você conhecerá os seguintes assuntos:

- Gerenciamento de vulnerabilidades em sistemas e redes;
- Técnicas de verificação de vulnerabilidades;
- Vulnerabilidades e Exposições Comuns;
- Verificação Intrusiva e Não Intrusiva;
- Varreduras de segurança: credenciada e não credenciada;
- Falsos positivos, falsos negativos, análise de logs;
- Revisão de configurações.

Aula 01

Gerenciamento de Vulnerabilidades

Avaliações de Segurança —

AVALIAÇÕES DE SEGURANÇA

- Primeiro a varredura identifica *hosts*, topologia da rede e serviços/portas.
- É estabelecida uma superfície de ataque geral.
- As avaliações são utilizadas para testar vulnerabilidades do ambiente.
- O NIST (SP 800-115) identificou três atividades principais:
 - Testar o objeto em avaliação;
 - Examinar objetos de avaliação;
 - Entrevistar pessoal.



Fonte: CleanCloud, 2023.

Disponível em: <<https://cleancloud.io/nist-conheca-um-dos-principais-frameworks-da-ciberseguranca/>>.

Acesso em: 21 mar. 2024.



Gestão de Vulnerabilidades

AVALIAÇÕES DE SEGURANÇA

- Os principais tipos de avaliação de segurança são:
 - Verificação de vulnerabilidade;
 - Caça a ameaças;
 - Testes de penetração.
- Nosso foco neste momento será a verificação de vulnerabilidades.

Fonte: LinkedIn, 2020.

Disponível em: <<https://pt.linkedin.com/pulse/como-fazer-gest%C3%A3o-de-vulnerabilidades-em-8-passos-hamir-campos>>.

Acesso em: 21 mar. 2024.



VERIFICAÇÃO DE VULNERABILIDADES

- Trata-se do processo de identificação, avaliação e análise das fraquezas e falhas de segurança.
- Analisa sistemas, redes, aplicativos ou infraestrutura de TI.
- As verificações podem ser manuais ou automatizadas.
- Apontam para a necessidade de ajustes na segurança e correções de *software*.



TÉCNICAS DE VERIFICAÇÃO DE VULNERABILIDADES

— Podem ser categorizadas em dois grandes grupos, muito embora sejam aplicadas em conjunto na maioria das vezes:

- 1 Varreduras automatizadas:
 - Uso de *software* especializado.
 - É configurada com assinaturas e *scripts*.
 - Existem vários tipos de *scanners* otimizados para diferentes tarefas.
 - Exige atualizações pois podem não ser capazes de detectar vulnerabilidades novas ou personalizadas.



TÉCNICAS DE VERIFICAÇÃO DE VULNERABILIDADES

- Exemplos de ferramentas disponíveis para varreduras automatizadas:

1. Nmap (*Network Mapper*).
2. OpenVAS (*Open Vulnerability Assessment System*)
3. Nessus
4. Burp Suite
5. Wireshark



TÉCNICAS DE VERIFICAÇÃO DE VULNERABILIDADES

2 Testes manuais:

- Análise minuciosa feita por profissionais de segurança cibernética.
- Exige especialização.
- Identificam vulnerabilidades não detectadas pelas ferramentas automáticas.
- São úteis para avaliar a segurança de sistemas complexos.



VULNERABILIDADES E EXPOSIÇÕES COMUNS

Common Vulnerabilities and Exposures (CVE):

- É uma iniciativa global.
- Trata-se de um sistema internacional de identificação e nomeação de vulnerabilidades de segurança cibernética.
- É mantido e gerenciado pela organização MITRE Corporation.
- Conta com a colaboração de várias outras entidades e especialistas.



Fonte: Medium, 2023.

Disponível em: <<https://medium.com/@tarponise/cve-o-que-%C3%A9-e-como-funciona-7da9aadee1e6>>.

Acesso em: 21 mar. 2024.



Fonte: Mente Binária, 2019.

Disponível em: <<https://www.mentebinaria.com.br/noticias/porta-mente-bin%C3%A1ria/n%C3%A3o-dependa-apenas-do-cve-para-descobrir-falhas-de-seguran%C3%A7a-r195/>>.

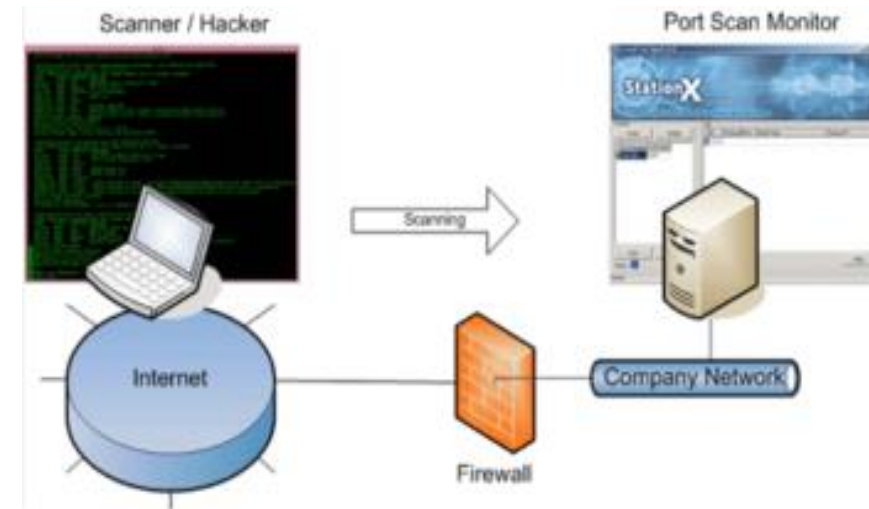
Acesso em: 21 mar. 2024.

VULNERABILIDADES E EXPOSIÇÕES COMUNS

- O sistema de nomeação do CVE segue um padrão bem definido.
- Registro de entrada de uma vulnerabilidade no CVE:
 1. Um identificador no formato CVE-YYYY-####;
 2. Descrição da vulnerabilidade;
 3. Uma lista de referência de URLs;
 4. A data em que a entrada de vulnerabilidade foi criada.

VERIFICAÇÃO INTRUSIVA E NÃO INTRUSIVA

- São duas abordagens distintas de verificação e análise de vulnerabilidades.
- A diferença está não só nas funcionalidades mas também no impacto sobre os sistemas e infraestrutura durante a verificação.
- A intrusividade é uma medida do quanto o *scanner* interage com o alvo.



Fonte: GTA/UFRJ.

Disponível em:

<https://www.gta.ufrj.br/grad/16_2/2016VARPORT/>.

Acesso em: 21 mar. 2024.

VERIFICAÇÃO INTRUSIVA E NÃO INTRUSIVA

- 1 Varreduras intrusivas (ou ativas):
 - Possuem ações que podem impactar o sistema ou rede verificados.
 - Usa algum tipo de conexão de rede com o alvo.
 - Pode causar travamento ou interrupção no alvo.
 - Fazem exploração real de vulnerabilidades.
 - Devem ser realizadas em ambiente controlado.

VERIFICAÇÃO INTRUSIVA E NÃO INTRUSIVA

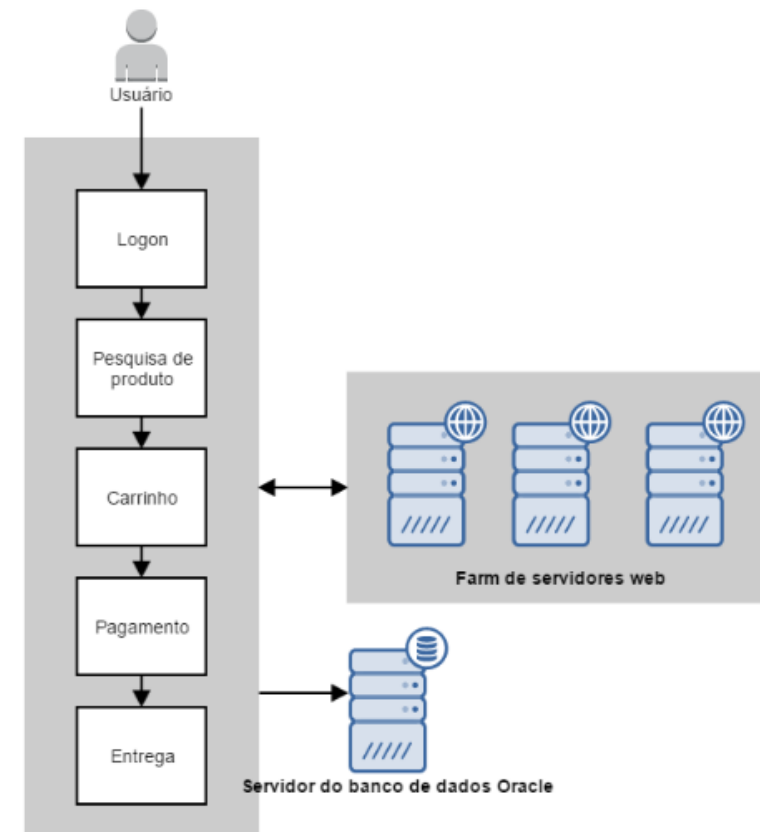
- Exemplos de varreduras intrusivas: Tentativa de autenticação com credenciais incorretas e uso de *exploits* ou técnicas de invasão.
- Vantagens: Verificam a exploração real de vulnerabilidades e checam a resistência a ataques.
- Desvantagens: Potencial para causar impacto adverso como interrupções de serviço.

VERIFICAÇÃO INTRUSIVA E NÃO INTRUSIVA

2 Varreduras não intrusivas (ou passivas):

- Analisa evidências indiretas.
- Projetados para não causar impacto nos sistemas verificados.
- A vantagem é que são seguras e não causam interrupções.
- A desvantagem é que podem não detectar vulnerabilidades de forma abrangente.

A análise de log monitora um site de varejo



Fonte: Broadcom Inc., 2019.

Disponível em: <https://techdocs.broadcom.com/br/pt_br/ca-enterprise-software/it-operations-management/unified-infrastructure-management/8-5-1/integrando-outros-produtos-da-ca/an_lise-de-log.html>.

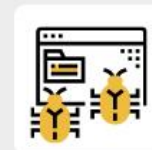
Acesso em: 21 mar. 2024.

VERIFICAÇÃO INTRUSIVA E NÃO INTRUSIVA

- Exemplos de varreduras não intrusivas:

1. Coleta de informações por meio de análise de tráfego de rede;
2. Pesquisa de informações publicamente disponíveis;
3. Análise de configurações de sistemas;
4. Verificação de portas abertas.

Vulnerabilities of open ports



Unauthorized
network access



Exposed network
vulnerabilities



Denial-of-service
attacks

Fonte: Blog ACSoftware, 2021.

Disponível em: <<https://blogac.me/desvendando-ameacas-de-portas-abertas-e-aumentando-a-seguranca-com-ferramentas-de-varredura-de-portas/>>.

Acesso em: 21 mar. 2024.



VARREDURA CREDENCIADA VS. NÃO CREDENCIADA

- 1 A escolha dependerá dos objetivos da avaliação e de especificidades do ambiente.
- 2 Na maioria dos casos é recomendável usar ambas as abordagens.
- 3 Permitirá uma análise mais abrangente.
- 4 Pode abordar análise de vulnerabilidades internas e externas.

VARREDURA CREDENCIADA VS. NÃO CREDENCIADA

1 Varredura credenciada:

- Exige o uso de credenciais válidas com anuência dos donos dos sistemas.
- É um tipo de verificação mais intrusiva do que a não credenciada.
- Permite o acesso às áreas mais profundas e restritas dos sistemas.
- Podem fornecer resultados mais detalhados e precisos.
- Identificam vulnerabilidades não visíveis por varreduras não credenciadas.



VARREDURA CREDENCIADA VS. NÃO CREDENCIADA

- Vantagem da varredura credenciada:
 - É particularmente eficaz na identificação de problemas de configuração e atualização.
- Desvantagem da varredura credenciada:
 - Exige a cooperação dos proprietários dos sistemas.
 - O acesso com credenciais deve ser concedido.
 - Pode ser mais demorado e complexo de configurar.



VARREDURA CREDENCIADA VS. NÃO CREDENCIADA

2 Varredura não credenciada:

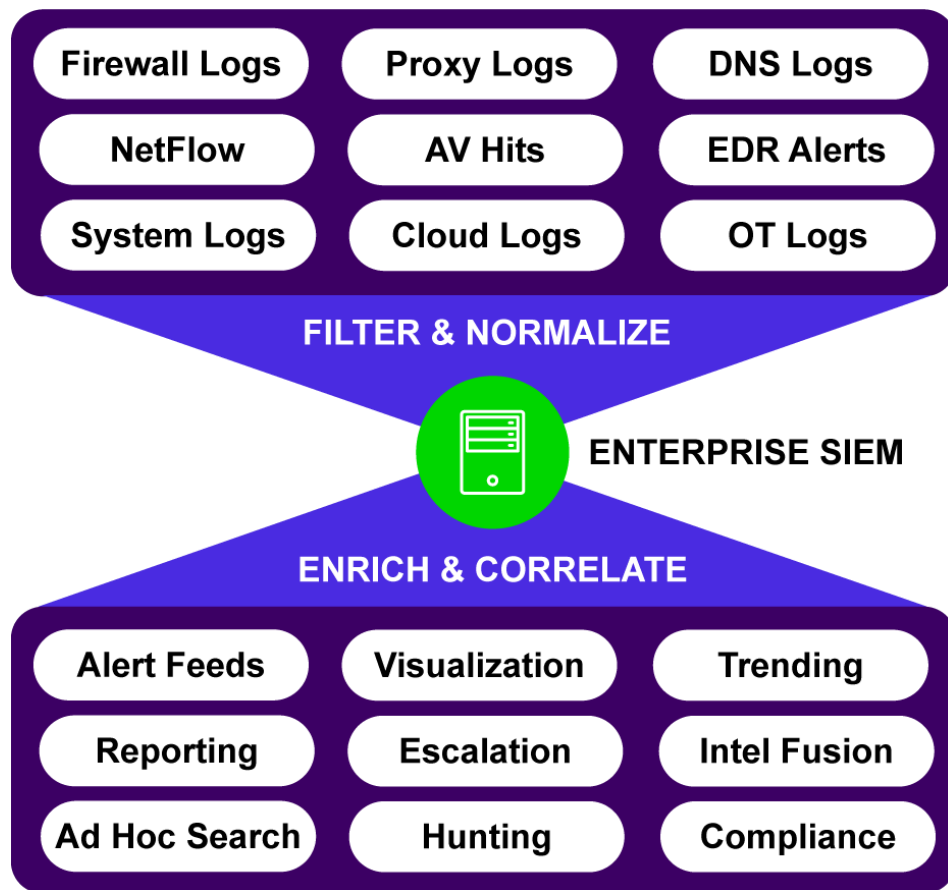
- Não faz uso de credenciais válidas.
- Não faz acesso a áreas restritas dos sistemas.
- Examina sistemas e redes de fora, como um observador externo.
- A verificação fica limitada a informações disponíveis publicamente.
- São mais rápidas e mais fáceis de implementar.
- Podem não detectar vulnerabilidades internas.



VARREDURA CREDENCIADA VS. NÃO CREDENCIADA

- Vantagem da varredura não credenciada:
 - Elas são úteis para identificar vulnerabilidades que podem ser exploradas por invasores externos os quais não possuem permissões.
- Desvantagem da varredura não credenciada:
 - Podem não detectar problemas de configuração e atualização devido à falta de acesso com credenciais.





Fonte: SideChannel, 2023.

Disponível em: <<https://www.sidechannel.blog/falsos-positivos-no-contexto-de-deteccao-de-ameacas/>>.

Acesso em: 21 mar. 2024.

FALSOS POSITIVOS, FALSOS NEGATIVOS E ANÁLISE DE LOG

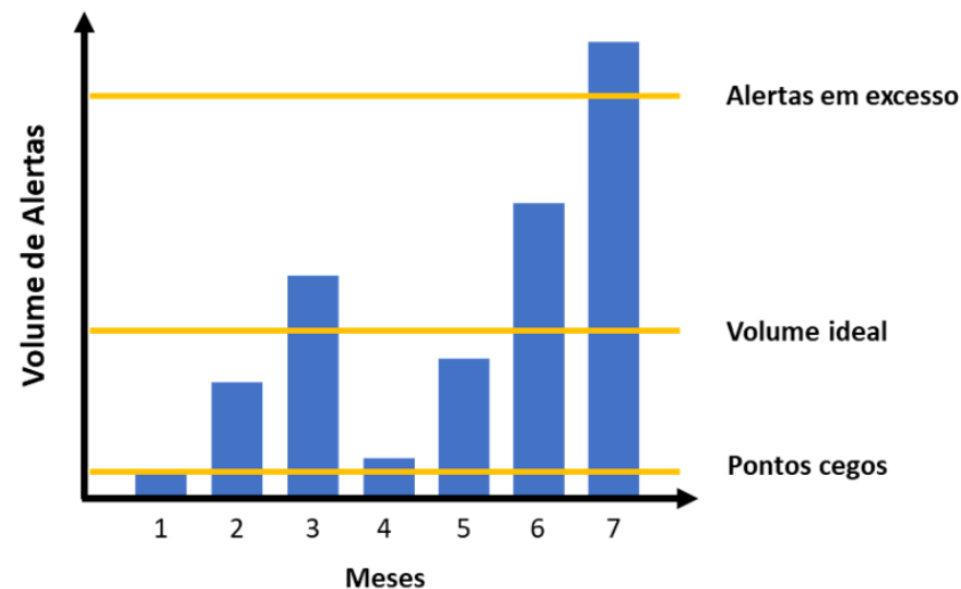
1 Falso positivo:

- Ocorre quando a ferramenta de verificação identifica erroneamente uma vulnerabilidade que na realidade não existe no sistema ou rede.
- Podem levar a tempo desperdiçado na investigação e correção de problemas inexistentes.
- O verdadeiro positivo ocorre quando o resultado indica corretamente a presença de uma condição ou característica que está presente de fato.

FALSOS POSITIVOS, FALSOS NEGATIVOS E ANÁLISE DE LOG

2 Falso negativo:

- Ocorre quando uma vulnerabilidade que está presente no sistema ou rede não é detectada pela ferramenta de verificação.
- Como resultado, vulnerabilidades reais não serão tratadas.
- Traz aumento de risco.
- O verdadeiro negativo ocorre quando um teste indica corretamente a ausência de uma condição ou característica que não está presente.



Fonte: SideChannel, 2023.

Disponível em: <<https://www.sidechannel.blog/falsos-positivos-no-contexto-de-deteccao-de-ameacas/>>.

Acesso em: 21 mar. 2024.



Fonte: Daniel Donda, 2022.

Disponível em: <<https://danieldonda.com/gerenciamento-e-analise-de-logs/>>.

Acesso em: 21 mar. 2024.

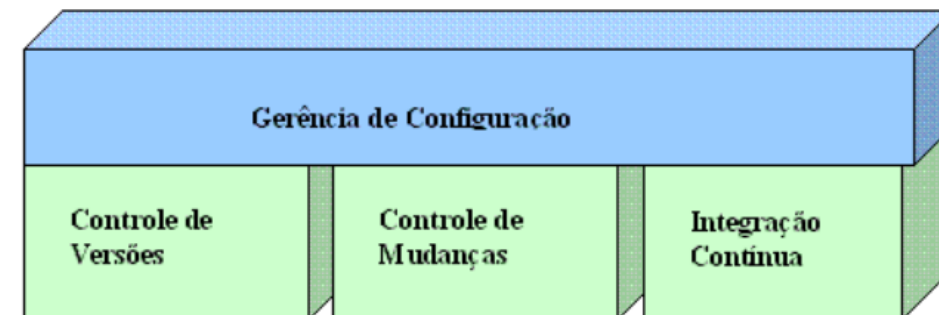
FALSOS POSITIVOS, FALSOS NEGATIVOS E ANÁLISE DE LOG

3 Análise de Logs:

- Envolve a revisão de registros de eventos e atividades de sistemas, aplicativos e redes.
- Visa confirmar ou não os resultados das ferramentas de verificação.
- Ajuda a distinguir entre falsos positivos, falsos negativos e fragilidades reais.
- Esta pode ser uma tarefa complexa.

REVISÃO DE CONFIGURAÇÃO

- Trata-se da análise e ajuste das configurações de sistemas, aplicativos e redes.
- Etapas do processo:
 - Identificação das Configurações.
 - Avaliação de Conformidade.
 - Análise de Vulnerabilidades.
 - Documentação e Registro.
 - Implementação de Correções.
 - Teste e Validação.



Fonte: DevMedia, 2022.

Disponível em: <<https://www.devmedia.com.br/quick-tips-gerencia-de-configuracao-parte-1/13708>>.

Acesso em: 21 mar. 2024.

3



Você chegou ao final da Aula 01
Gerenciamento de Vulnerabilidades